Security & Backup Plan

How the shared VersaNext platform will protect client data and make sure it can always be recovered.

1. Real logins and permissions

- Every person gets their own account. Passwords are stored only as secure hashes, or users sign in with passkeys (Face ID, fingerprint, device PIN).
- Optional two-step sign-in for every client; on by default for owners and admins.
- Role-based permissions (owner, manager, staff, crew) so people only see what their job needs.
- Each client's data is kept separate, and one client can never see another's.
- Shared default PINs like 1234 are retired.

2. Encryption and secrets

- All traffic is encrypted in transit (HTTPS only).
- Data is encrypted at rest; Cloudflare encrypts its database (D1) and file storage (R2) by default.
- Keys, passwords and connection secrets live only on the server as protected secrets, never in website code.
- All code repositories become private.

3. Audit history

- Every add, change, delete, sign-in and export is recorded: who, what, when, and the before and after values.
- The history can't be edited by users and is kept with each client's backups.

4. Automatic backups

- **Point-in-time restore:** Cloudflare D1 Time Travel is always on and can roll a database back to any minute in the last 30 days (paid plan).
- **Nightly copies:** each night the database is exported to separate Cloudflare R2 storage as a dated copy, kept beyond 30 days (for example 90 daily plus 12 monthly).
- **Protected copies:** backup storage uses retention locks so copies can't be overwritten or deleted early. Photos, receipts and documents are stored in R2 and copied the same way.
- **Restore test:** once a month we restore a backup to a test copy and confirm it works.

5. Monitoring and alerts

- Uptime and error monitoring on every client app, with alerts to the VersaNext team.
- Rate limits on sign-in and code entry to stop guessing attacks, plus alerts on repeated failures.
- Alerts if a nightly backup fails or doesn't run.
- Updates are tested first, then rolled out to all clients at once.

6. Accounts, email and files

- Move all apps and data off personal Gmail to company-owned VersaNext accounts.
- Replace "anyone with the link" photos and documents with private storage that requires sign-in.
- Close the open data and file-reading links on the current backends.

7. Migration order

1. **Urgent cleanup now:** make public repos private, rotate any exposed codes or keys, close open data links (Southern Concrete, Miller, TSShourtracker).
2. **Platform foundation:** logins, permissions, database, audit history and backups.
3. **VersaNext CRM and employee portal** move first (internal, lowest risk).
4. **TSShourtracker** (holds pay data).
5. **Southern Concrete and Miller** Field Desk apps.
6. **Fielder** Field Desk app.
7. **Sparkle** app.

Each move: copy the data, run old and new side by side briefly, confirm with the client, then switch off the old version.

> Changes to live client apps will be made only with Austin's approval. This plan does not claim any outside certification (such as SOC 2 or HIPAA). Those would require a separate formal audit.